

NCA Sponsored Training

Day 2 – Morning Session (Lab)

Password Cracking

Ahmed Didouh

Madinah

13/01/2026



rc3.kaust.edu.sa





Outline



1. Introduction to Password Cracking

- *Definition and motivations*
- *Test password security*
- *Prior data breach*

2. HashCat

- *Introduction*
- *Brute-force*
- *Mask attacks*
- *Dictionary attack*
- *Hybrid attack*

3. John the Ripper

- *Hybrid attack*
- *Combination Attack*



Password Cracking - Meaning



Password cracking refers to various measures used to discover computer passwords.

Why?

- To recover a password for authorize access purpose (misplacing, missing)
- To discover weak password in corporate networks/applications (Penetration Test)
- To gain unauthorized access to an account without the owner's awareness





Test Password Security



1) Visit the following URL:

<https://lowe.github.io/tryzxcvbn/>

This website estimates the strength of passwords you enter. Passwords never leave your browser – if you are so inclined, you can confirm as much by perusing the source code and/or by opening your browser developer tools and observing the (java)script that runs when you enter passwords.

2) Try out different passwords to see how strong they are



Check an Account for a Prior Data Breach



- 1) Check to see if one of your online accounts has already been breached:

<https://haveibeenpwned.com>

Type in one of your email accounts or usernames to see if it has already been compromised in a data breach.



Password Cracking - How to



- DIFFERENT WAYS OF CRACKING THE PASSWORDS:

- Using Keyloggers



- Social Engineering (Phishing)



- Guessing



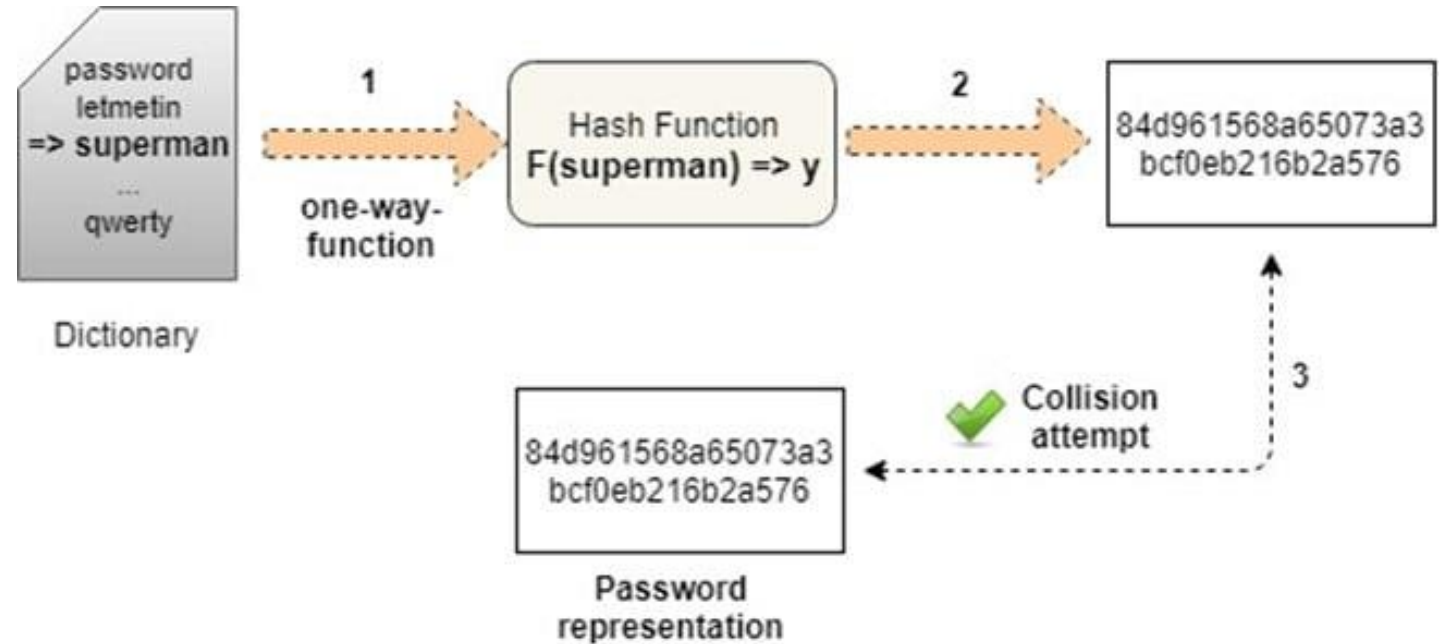
- **OFFLINE attacks:** Brute Force, Dictionary attack, Hybrid Attack, etc.



Offline Attacks - How to



1. Generate a “Candidate”
2. Apply the hash function
3. Verify the equality





Offline Attacks - Tools



- **CeWL** is a Custom WordList Generator. It allows you to create word lists by spidering websites.
- **Hashcat** is the world's fastest and most advanced password recovery utility.
- **John the Ripper** is a well-known free open-source password cracking tool. It offers password cracking for a variety of different password types (OS, common web apps, compressed archives, etc.)





Hashcat



- It is an advanced password recovery tool
- It is multiplatform (Windows, Linux, MacOS)
- Support multiple types of attacks
- It is used to reverse hash by generating password candidates





Hashcat – How Candidates are Generated



- **Brute-force**: Tries all combinations from a given *keyspace*. It is the easiest of all the attacks.
- **Mask Attack**: Try all combinations from a given *keyspace* just like in Brute-Force attack, but more specific.
- **Wordlist Attack**: Read line by line from a textfile (aka “dictionary” or “wordlist”) and try each line as a password candidate.
- **Combinator Attack**: Each word of a dictionary is appended to each word in a dictionary.
- **Hybrid Attack**: is just a Combinator attack. One side is simply a dictionary, the other is the result of a Brute-Force attack.



Hashcat – Getting Started



1. Open a command prompt
2. Go to the Hashcat folder
3. Execute the command “***hashcat -h***” to visualize the user guide
4. You can also find it online: <https://hashcat.net/wiki/doku.php?id=hashcat>

```
C:\Users>
C:\Users>cd C:\KAUST\NCA Training\hashcat-6.2.6

C:\KAUST\NCA Training\hashcat-6.2.6>
C:\KAUST\NCA Training\hashcat-6.2.6>hashcat -h
hashcat (v6.2.6) starting in help mode

Usage: hashcat [options]... hash|hashfile|hccapxfile [dictionary|mask|directory]...

- [ Options ] -

Options Short / Long      | Type | Description                                     | Example
=====+=====+=====+=====
-m, --hash-type           | Num   | Hash-type, references below (otherwise autodetect) | -m 1000
-a, --attack-mode         | Num   | Attack-mode, see references below                 | -a 3
-V, --version             |       | Print version                                     |
```



hashcat [options] input1 input 2

Tell hashcat what to do
Ex: **-b** -> benchmark



The hash to be reversed, or
the path of a file with one or
more hashes



Give to hashcat
other resources
Ex: a dictionary



Hashcat – Basic Options



-m, --hash-type:

Hash-type (MD5, SHA1, etc.) followed by the Hash modes numbers

Example: -m 100

Most used Hash modes numbers:

- 0 -> MD5
- 100 -> SHA1
- 1400-> SHA256
- 1700-> SHA-512



Hashcat – Basic Options



-a, --attack-mode :

Attack mode (Brute force, Hybrid, etc.) followed by the attack modes numbers

Example: -a 3

Most used Attack modes numbers:

- 0 -> Straight
- 1 -> Combination
- 3 -> Brute-force
- 6 -> Hybrid Wordlist + Mask



Let's get hands dirty...



Test Password Security



1) Run the hashcat benchmark to check how fast is your system with MD5

hashcat -b -m 0

```
OpenCL API (OpenCL 3.0 CUDA 12.1.112) - Platform #1 [NVIDIA Corporation]
=====
* Device #1: NVIDIA GeForce GTX 1650 Ti, 3520/4095 MB (1023 MB allocatable), 16MCU

OpenCL API (OpenCL 3.0 ) - Platform #2 [Intel(R) Corporation]
=====
* Device #2: Intel(R) UHD Graphics, 13024/26112 MB (2047 MB allocatable), 24MCU

Benchmark relevant options:
=====
* --optimized-kernel-enable

-----
* Hash-Mode 0 (MD5)
-----

Speed.#1.....: 12483.1 MH/s (42.69ms) @ Accel:256 Loops:1024 Thr:128 Vec:8
Speed.#2.....:   462.4 MH/s (49.39ms) @ Accel:8 Loops:512 Thr:256 Vec:4
Speed.#*.....: 12945.5 MH/s
```

Your
Devices

Results



Hashcat - Benchmark



Run the benchmark for the following algorithms:

- SHA-1
- SHA2-256
- SHA3-256
- NTLM





Hashcat – Brute-force



Reverse the following SHA2-256 hash:

8f8472a2f6ec348bfc7577a035c7f34a04c62f0c757b54687e1175236dcf393b

With the command:

hashcat -m 1400 -a 3



Hashcat – Mask attack



Advantage over Brute-Force:

- reduce the password candidate keyspace to a more efficient one.

Example: We want to crack the password: Julia1984

Keyspace:

upper-case letters, lower-case letters and digits

The Password length is 9 = 62^9 (13.537.086.546.263.552) combinations.

Hash rate = 100MH/s = more than **4 years to complete**.

With Mask attack we can reduce the keyspace to

$52 * 26 * 26 * 26 * 26 * 10 * 10 * 10 * 10$ (237.627.520.000) combinations. With the same hashing rate of 100MH/s, this requires just **40 minutes** to complete.



Hashcat – Mask attack – How to



```
- [ Built-in Charsets ] -
```

```
? | Charset
```

```
====+=====
```

```
l | abcdefghijklmnopqrstuvwxyz
```

```
u | ABCDEFGHIJKLMNOPQRSTUVWXYZ
```

```
d | 0123456789
```

```
h | 0123456789abcdef
```

```
H | 0123456789ABCDEF
```

```
s | !"#$%&'()*+,-./:;<=>?@[\\]^_`{|}~
```



Hashcat – Mask attack



Example: We want to crack the password: Julia1984

Hash:

028A44E44A6A2EDCE609CAABDEC635BE

Command:

**hashcat -m 0 -a 3 028A44E44A6A2EDCE609CAABDEC635BE
?u?l?l?l?d?d?d?d**



Hashcat – Mask attack – Custom Charset



The **custom Charset** commandline-parameters have four analogue shortcuts called -1, -2, -3 and -4. You can specify the chars directly on the command line or use a so-called hashcat charset file (plain text file with .hcchr extension which contains the chars/digits to be used on the 1st line of the file).

Example:

command: hashcat -a 3 -1 ?l?d ?1?1?1?1?1

keyspace: aaaaaa – 99999



Hashcat – Mask attack



1) SHA1 (6 digits): **1052dade1b76d3c28feaaafa57ad6a09b202c9fc**

2) SHA1 (digits and lowercase, length 6)

7782ded1754e94eea8fc6045edf1f024eb45dff3

3) SHA1 (digits and lowercase, length 8)

f83c9c35b522c910eaa5ed779de41811261eb9d0

4) SHA256 (lowercase, length 8)

29b48c7194c25f057bf5b4b136266e676a1baf4510e798e2b29ccc68cfa4d01f

5) SHA256 (digits and lowercase, length 8)

ba2bfb146095669e9ac997851982c45ad80bc0e0f0e05a8019ef2c3b2654c8e3



Hashcat – Hybrid Attack



The full Brute-Force keyspace is either appended or prepended to each of the words from the dictionary. That's why it's called “hybrid”.

Syntax: hashcat -m 0 -a “6 or 7” “hash” “dictionary path” “mask”

Example:

- **hashcat -m 0 -a 6 5D7845AC6EE7CFFFAFC5FE5F35CF666D password.lst ?d?d?d**
- **hashcat -m 0 -a 7 5D7845AC6EE7CFFFAFC5FE5F35CF666D ?d?d?d password.lst**



Hashcat – Hybrid Attack - Exercise



Your friend forgot his Windows password. He usually uses a combination of a **name** of one of his close family members combined with a **four-digit** year corresponding to a special event for him, terminated by a **special character**.

After recovering the hashed password (SHA2-256)

d274bee7f8fbcedb0d5ca26f106ec76a706c7b0435fd1cb4d27813cab21f6468

and knowing that his wife's name is Francine, their sons are Mark, Julia, Bobby and Priscilla, are you able to help him recovering his password?



Check an Account for a Prior Data Breach



- 1) Check to see if one of your online accounts has already been breached:

<https://haveibeenpwned.com>

Type in one of your email accounts or usernames to see if it has already been compromised in a data breach.



Hashcat – Worldlist Attack



- Download a Dictionary or create your own Wordlist
- Use Hashcat with attack mode 0
- Syntax: `hashcat -m 0 -a 0 "hash" "dictionary path"`

Example:

```
hashcat -m 0 -a 0 807FF71B3301262E222AD05E5B7C4325 password.lst
```



John the Ripper — Install & First Run



Install

```
$ sudo apt update && sudo apt install -y john
```

Create a lab folder and enter it

```
$ mkdir D2MLab && cd D2MLab
```

Import exercise folder

```
$ wget https://www.openwall.com/john/i/john-1.8.0.tar.xz
```

```
$ tar -xvf john-1.8.0.tar.xz
```

```
$ cd john-1.8.0/run
```

Download crack-these-please.txt

Use a web browser for the download :

<https://www.dropbox.com/s/3or7x52xb35kvau/crack-these-please?dl=0>

```
$ more password.lst
```



John – Basic Options



--wordlist=, --rules :

John reads candidate passwords from the specified wordlist <FILE> and, when --rules is used, applies mutation rules (e.g., case changes, appending digits, substitutions) before testing them against the <hashfile>

Example: john --wordlist=passwords.txt --rules hashes.txt

Key concepts in this command:

- --wordlist: Specifies the file containing potential passwords.
- --rules: Applies pre-defined character mutations to every word in the list.
- <hashfile>: The file containing the hash(es) to crack.



John the Ripper - Hybrid Attack



A hybrid attack checks for variations of a word or a combination of dictionary words.

Example: We want to crack a password that starts with a dictionary word and ends with a few digits.

Hash File:

crack-these-please (This file contains the hashes)

Command:

```
$ john --wordlist=password.lst --rules crack-these-please
```



John the Ripper - Combination Attack



In default usage, John the Ripper executes dictionary, hybrid, and bruteforce attacks in combination automatically.

Example:

- Let John run long enough to do some more cracking.
- Note the time it took and how many additional passwords it was able to crack.
- Observe the characteristics of the cracked passwords: length, case variations, symbols, and numerals.

Note:

Note: Getting all passwords could take forever; you can hit CTRL-C to stop the run if it is taking too long.

Command:

```
$ john crack-these-please
```

Do you have any questions?



rc3.kaust.edu.sa



Follow us @rc3kaust

